

Informe CVSS

Desde 2025, CVSS ha dejado de ser “solo una nota del 0 al 10” para convertirse en un ecosistema de métricas mucho más granular (CVSS 4.0), que los estados —incluida España— están empezando a integrar en sus sistemas nacionales de gestión de vulnerabilidades y riesgo digital.¹²³

1. Qué ha cambiado realmente en CVSS desde 2025

CVSS 4.0 es ya la referencia “de futuro”, aunque CVSS 3.1 sigue conviviendo en muchas bases de datos y herramientas.⁴⁵

Cambios estructurales clave:

- Cuatro grupos de métricas: Base, Threat (antes Temporal), Environmental y Supplemental.⁶¹
- Nuevo léxico de puntuaciones: CVSS-B, CVSS-BT, CVSS-BE, CVSS-BTE, separando claramente “lo técnico” de “lo contextual”.⁷⁶
- Desaparición de ciertas métricas temporales clásicas (p.ej. Remediation Level, Report Confidence), sustituidas por un conjunto de Threat más simple y utilizable.⁸

Idea práctica: el CVSS “crudo” (Base) describe la severidad técnica; la combinación con Threat y Environmental construye algo mucho más cercano a riesgo operacional, que es donde un país se juega la piel.⁶⁷

2. Nuevas métricas CVSS 4.0 y su lógica

2.1. Métricas Base refinadas

El grupo Base describe propiedades intrínsecas de la vulnerabilidad, constantes en el tiempo y entre organizaciones.⁸

Principales movimientos:

1 <https://www.incibe.es/incibe-cert/alerta-temprana/vulnerabilidades/cve-2025-15579>

2 https://www.incibe.es/en/incibe-cert/early-warning/vulnerabilities?field_vul_product=\&page=5

3 <https://www.incibe.es/incibe-cert/blog/cvss-v40-avanzando-en-la-evaluacion-de-vulnerabilidades>

4 <https://www.sysdig.com/blog/cvss-version-4-0-whats-new>

5 <https://www.first.org/cvss/specification-document>

6 <https://www.incibe.es/incibe-cert/alerta-temprana/vulnerabilidades/cve-2025-15579>

7 <https://www.first.org/cvss/specification-document>

8 <https://www.incibe.es/incibe-cert/alerta-temprana/vulnerabilidades/cve-2025-15579>

- Separación de la complejidad:
Attack Complexity (AC): dificultad técnica de explotación frente a defensas y controles.⁵⁹
Attack Requirements (AT): condiciones previas necesarias para que el ataque sea viable (estado del sistema, configuración, etc.).¹⁰⁹
- Revisión de la interacción de usuario: la métrica UI se refina para describir mejor cuándo y cómo el usuario tiene que participar, mejorando la clasificación de ataques tipo phishing, drive-by, etc.¹⁰
- Reemplazo del “Scope” clásico: el antiguo Scope se sustituye por una separación entre impactos en el sistema vulnerable y en sistemas subsecuentes, lo que permite expresar mejor ataques en arquitecturas complejas (cloud, microservicios, OT/IoT).¹⁰
- Attack Complexity (AC): dificultad técnica de explotación frente a defensas y controles.⁵⁹
- Attack Requirements (AT): condiciones previas necesarias para que el ataque sea viable (estado del sistema, configuración, etc.).¹⁰⁹

Ejemplo ilustrativo para un regulador: una vulnerabilidad en un router de operador con impacto en “sistema subsecuente” ya no es “un 9,5 genérico”, sino un 9,5 con una huella formal sobre cuántos sistemas de terceros arrastra.⁹¹⁰

2.2. Threat metrics (ex-Temporal)

Las Threat metrics permiten ajustar el score en función del estado del ecosistema de explotación:

- Simplificación de Exploit Maturity: se reduce y renombra como Exploit Maturity (E), con valores consolidados (por ejemplo, “Attacked”) que reflejan que ya se explota activamente en el mundo real.⁸
- Eliminación de métricas poco utilizadas o ambiguas (p.ej. Remediation Level y Report Confidence), reduciendo ruido y subjetividad.⁸

En términos nacionales: estas métricas abren la puerta a sistemas de alerta temprana donde una CVE que pasa de “teórica” a “explotada” aumenta automáticamente su prioridad para CERT nacionales y operadores críticos.¹¹¹²

⁹ https://www.incibe.es/en/incibe-cert/early-warning/vulnerabilities?field_vul_product=\&page=5

¹⁰ <https://www.incibe.es/incibe-cert/blog/cvss-v40-avanzando-en-la-evaluacion-de-vulnerabilidades>

¹¹ <https://www.sysdig.com/blog/cvss-version-4-0-whats-new>

¹² <https://www.incibe.es/incibe-cert/blog/cvss-v40-avanzando-en-la-evaluacion-de-vulnerabilidades>

2.3. Métricas ambientales “de verdad”

El grupo Environmental pasa de ser el eterno olvidado a una pieza central: permite ajustar el score según la **criticidad local del activo, las dependencias y el entorno regulatorio**.¹³¹⁴

Usos típicos a nivel país:

- Incrementar el peso de vulnerabilidades que afectan a:
Infraestructuras críticas (energía, agua, transporte, salud).
Sistemas de administración electrónica y servicios esenciales al ciudadano.
- Afinar el impacto en función del despliegue real en el territorio (porcentaje de organizaciones expuestas, papel del activo en cadenas de suministro nacionales, etc.).
- Infraestructuras críticas (energía, agua, transporte, salud).
- Sistemas de administración electrónica y servicios esenciales al ciudadano.

2.4. Métricas suplementarias: donde asoma el mundo real

Gran novedad: CVSS 4.0 introduce métricas **Supplemental** que no cambian el score, pero sí lo contextualizan.¹⁵¹⁶

Entre ellas (según la especificación y los anuncios oficiales):

- Safety (S): impacto en seguridad física de las personas.⁷
- Automatable (A): grado en que el ataque puede automatizarse (botnets, gusanos, explotación masiva).⁷
- Recovery (R): facilidad de recuperación tras la explotación.⁷
- Value Density (V): cuánto valor/impacto concentrado hay por instancia vulnerable.⁷
- Vulnerability Response Effort (RE): esfuerzo necesario para responder y remediar.⁷
- Provider Urgency (U): urgencia declarada por el proveedor o CNA.⁷

A nivel estatal son oro puro, porque permiten seleccionar no solo “qué es grave”, sino “qué es grave, fácilmente automatizable, difícil de recuperar y con alto valor agregado por activo” —la tormenta perfecta.¹⁷¹⁸¹⁹

¹³ <https://thehackernews.com/2023/11/first-announces-cvss-40-new.html>

¹⁴ <https://www.first.org/cvss/specification-document>

¹⁵ <https://www.first.org/cvss/specification-document>

¹⁶ <https://blog.qualys.com/product-tech/2023/11/02/cvss-v4-is-now-live-and-what-do-you-need-to-know>

¹⁷ <https://www.first.org/cvss/user-guide>

¹⁸ <https://www.scip.ch/en/?labs.20231102>

3. Tendencias 2025+ en el uso de CVSS a nivel mundial

3.1. Coexistencia 3.1 / 4.0

- CVSS 4.0 está publicado y plenamente documentado por FIRST.¹³⁹¹
- Sin embargo, CVSS 3.1 sigue siendo el estándar dominante en muchas organizaciones y bases de datos, con una transición gradual en curso.¹⁴⁵

Efecto práctico: durante algunos años veremos CVE con doble score (3.1 y 4.0) y herramientas que recomponen el riesgo combinando ambos.²⁰²¹

3.2. Integración con bases de datos nacionales y sectoriales

- La NVD (NIST) sigue siendo la referencia norteamericana, pero se están creando bases complementarias a nivel regional, como la European Vulnerability Database (EUVD) impulsada en la UE en 2025 para centralizar vulnerabilidades relevantes para el mercado europeo.¹²
- ENISA actúa como CNA (CVE Numbering Authority) europea, coordinando divulgación y etiquetado de vulnerabilidades con impacto en Europa.¹²

Esto confluye en una tendencia clara: los estados ya no se limitan a consumir CVSS, sino que lo enriquecen con capas propias de criticidad nacional, normativa y cadena de suministro.²²²³

3.3. CVSS como entrada para la regulación

- La Directiva NIS2 y el Cyber Resilience Act europeos empujan a que organismos públicos y operadores de servicios esenciales mejoren sus procesos de gestión de vulnerabilidades, para lo cual CVSS sirve como métrica mínima común.¹¹¹²
- El EU Cyber Solidarity Act (en vigor desde febrero de 2025) refuerza capacidades de alerta, preparación y respuesta ante incidentes a nivel UE, con hubs nacionales y transfronterizos que naturalmente necesitarán métricas homogéneas como CVSS 4.0 para priorizar y coordinar actuaciones.¹¹

Traducción libre: sin CVSS (o equivalente), no hay orquesta; con CVSS 4.0, la partitura se vuelve más matizada.

¹⁹ <https://www.first.org/cvss/specification-document>

²⁰ <https://thehackernews.com/2023/11/first-announces-cvss-40-new.html>

²¹ <https://digital-strategy.ec.europa.eu/en/policies/cyber-solidarity>

²² https://www.incibe.es/en/incibe-cert/early-warning/vulnerabilities?field_vul_product=\&page=5

²³ <https://deepstrike.io/blog/vulnerability-statistics-2025>

4. España: INCIBE, CVSS y gestión nacional de vulnerabilidades

4.1. INCIBE-CERT como nodo central

En España, el **INCIBE-CERT** mantiene una base de datos de vulnerabilidades en español, basada en NVD gracias a un acuerdo de colaboración, con más de 75.000 registros traducidos y adaptados.²⁴

Tendencias claras:

- Uso explícito de CVSS en sus fichas de vulnerabilidad, incluyendo ya CVSS v4.0 para vulnerabilidades recientes (p.ej., CVE-2025-15579, CVE-2025-41002).²¹⁵
- INCIBE actúa además como CNA (CVE Numbering Authority), asignando y gestionando CVE que afectan a productos y servicios relevantes en España, etiquetados con vectores CVSS 4.0.¹⁶¹⁵

Así, España deja de ser mero consumidor de scores y se convierte en productor cualificado de información de vulnerabilidades con métricas estandarizadas.²⁵²⁶

4.2. Ejemplo real: vulnerabilidades gestionadas con CVSS 4.0

En vulnerabilidades recientes donde INCIBE figura como CNA, se publican vectores CVSS 4.0 indicando:

- Attack Vector, Attack Complexity, Attack Requirements, Privileges Required, User Interaction.
- Impactos en confidencialidad, integridad y disponibilidad, separados para sistemas vulnerables/subsecuentes según el modelo 4.0.¹⁶¹⁵

Esto habilita, para una hipotética “matriz de riesgo país”, la posibilidad de incorporar:

- % de vulnerabilidades críticas (CVSS-B $\geq$ 9) que afectan a sectores esenciales españoles.
- % de vulnerabilidades con alta automatización (Automatable = sí) y alto Value Density sobre activos en España.³⁷

4.3. España en el contexto europeo

España se alinea con las iniciativas europeas (NIS2, EU Cyber Solidarity Act, ENISA CNA) adoptando CVSS como lenguaje interoperable para compartir información de vulnerabilidades entre:

- INCIBE-CERT (ciudadanos y empresas).
- CCN-CERT (administraciones públicas).
- Operadores críticos y proveedores estratégicos sometidos a regulación sectorial.³¹²¹¹

Esto sugiere una futura convergencia hacia un marco de indicadores nacionales donde CVSS 4.0 será componente integrador, no fin en sí mismo.

²⁴ <https://hacking.onesec.mx/index.php/2025/08/guia-completa-cvss-v3-1-como-evaluar-vulnerabilidades-de-seguridad-en-2025/>

²⁵ <https://nvd.nist.gov/vuln/detail/CVE-2025-41002>

²⁶ <https://nvd.nist.gov/vuln/detail/CVE-2025-59905>

5. Indicadores e ideas de métricas CVSS aplicadas a nivel nacional (España en clave comparada)

Aquí empieza la parte “propositiva”: cómo transformar CVSS 4.0 en indicadores de política pública y gestión de riesgo país.

5.1. Ejes básicos de un cuadro de mando nacional

Con CVSS 4.0, un cuadro de mando territorial para España podría estructurarse en tres capas:

1) Severidad técnica agregada (CVSS-B)

- Número de vulnerabilidades nuevas por trimestre que afectan a organizaciones en España, estratificadas por rangos de CVSS-B (0-3,9; 4-6,9; 7-8,9; 9-10).³
- Distribución sectorial (sanidad, energía, transporte, AAPP, financiero, industria, pymes digitales).
- Tiempo medio desde publicación de la CVE hasta que aparece una explotación “Attacked” en la métrica Threat (si la información está disponible).⁸¹²

2) Explotabilidad y automatización (Threat + Supplemental)

- % de vulnerabilidades críticas con Exploit Maturity = “Attacked”.⁸⁷
- % de vulnerabilidades críticas marcadas como Automatable, especialmente en sistemas expuestos a Internet.¹²⁷
- Número de incidentes nacionales correlacionados con CVE con alta automatización y alto Value Density, como indicador del “efecto multiplicador” del ataque.¹²⁷

3) Impacto y resiliencia (Environmental + Supplemental)

- Vulnerabilidades con Safety (S) activado en infraestructuras que puedan afectar a la integridad física de personas (OT, transporte, salud).⁷
- Recovery (R): tiempo medio y esfuerzo declarado para recuperación, como insumo para métricas nacionales de resiliencia (días de indisponibilidad, coste directo).¹¹⁷
- Provider Urgency (U): priorización de parches críticos según el propio proveedor, correlacionada con tiempos reales de despliegue en organizaciones españolas.³⁷

5.2. Tabla de ejes: CVSS 4.0 como palanca de indicadores país

Tabla de ejes comparativos (nivel internacional vs posible uso en España):

Eje CVSS 4.0	Uso típico global	Posible uso España a nivel nacional
CVSS-B (Base)	Clasificar severidad técnica CVE en bases como NVD173	KPI de exposición técnica nacional por sector y criticidad3
Threat metrics	Priorizar vulnerabilidades con exploits activos8	Sistema de alertas priorizadas en INCIBE-CERT/CCN-CERT23
Environmental	Ajustar riesgo según contexto organizacional18	Ajustar al contexto español: infraestructuras críticas, sector público, pymes
Supplemental (S, A,...)	Documentar automatización, seguridad física, esfuerzo, valor por activo7	Indicadores de riesgo país: automatización, impacto físico, esfuerzo de respuesta
Nomenclatura B/BT/BE	Diferenciar severidad técnica de riesgo ajustado67	Separar métricas de supervisión técnica (B) y regulatoria/operativa (BT/BE/BTE)
CNA nacionales	Emisión de CVE y vectores locales121615	INCIBE como productor de información de vulnerabilidades crítica para España1615

5.3. Algunas preguntas inquisitivas para una encuesta “de país”

Si se quiere usar este marco para un estudio o encuesta nacional (CISOs, reguladores, operadores), algunas preguntas sugerentes podrían ser:

- “¿Con qué frecuencia recalcula usted el score CVSS ambiental (Environmental) para activos críticos en su organización?”
- “Cuando una vulnerabilidad se marca como ‘Attacked’ en Threat, ¿en cuántas horas/días se actualizan sus prioridades de parcheo?”
- “¿Utiliza explícitamente métricas suplementarias (Automatable, Recovery, Provider Urgency) en sus procesos de priorización, o se queda con el score base clásico y un suspiro filosófico?”
- “En su contexto, ¿qué pesa más a la hora de priorizar: el CVSS-B o la combinación CVSS-BTE, donde la E de Environmental recoge la singularidad de su organización española, mediterránea y con menos paciencia que presupuesto?”

6. Lecciones desde la perspectiva de riesgo, Zero Trust y resiliencia

Desde la óptica de un consorcio de CISOs, criptógrafos y estrategias de resiliencia, las tendencias 2025+ en CVSS sugieren varias buenas prácticas:

- No fetichizar el número: CVSS 4.0 facilita separar severidad técnica (CVSS-B) de riesgo contextual (BT/BE/BTE); conviene explotar esa separación, no esconderla.⁶¹
- Conectar CVSS con Zero Trust: altos valores en Automatable y baja Attack Complexity deberían disparar controles de acceso mínimos, segmentación, reforzamiento de identidades privilegiadas según recomiendan guías y estudios globales de CISO.¹⁸⁸
- Incorporar CVSS a métricas de resiliencia: Recovery y Vulnerability Response Effort son metrónomos para medir cuán rápido se absorbe el golpe, en línea con las ambiciones de resiliencia del EU Cyber Solidarity Act.¹¹⁷
- Pensar país, no solo empresa: la aparición de EUVD y la función de ENISA como CNA muestran que Europa quiere métricas comparables; España, con INCIBE-CERT como nodo, tiene los ingredientes para construir indicadores propios que hablen este idioma común.³¹²¹¹

192021222324252627282930